

## Chapter 12

**Compare and contrast concepts  
and strategies to protect data**

# Introduction

- This chapter discusses data protection, a complex issue involving diverse data types like regulated, trade secrets, and IP.
- It highlights the need for security measures like encryption, hashing, masking, and tokenization, as well as geographic restrictions.
- This chapter discusses the importance of a tailored combination of elements for robust data protection in the era of cyber-attacks.

# Data Types

Data is crucial for modern businesses, covering personal, medical, commerce, and customer data. It's protected from malicious actors through regulated data, which is subject to specific laws and regulations.

**Regulated data** refers to data subject to specific laws and regulations.

- **Personally Identifiable Information (PII):** PII refers to unique personal information such as social security number, biometric data, driving license number, employee records, mobile phone number, or email address.
- **Protected Health Information (PHI):** PHI refers to a person's unique health data, including medical history, diseases, treatments, and test results like MRI scans or X-rays.
- **Financial data:** Financial data, including electronic payment details, is subject to regulations and laws ensuring consumer privacy, anti-money laundering, and fraud prevention, including monitoring payments and defaults.
- **Legal data:** Legal data refers to confidential information related to legal proceedings, such as court cases, and is subject to privacy laws.
- **Intellectual Property (IP):** Intellectual property rights (IP) are creative innovations protected by regulations like patents and copyright laws, including trade secrets, patents, and copyright material.
- **Consumer data:** Consumer protection laws and privacy regulations may regulate consumer data, including purchase histories, preferences, and online behavior.
- **Government data:** Government agencies collect and use data subject to strict regulations for handling and disposal, including internal or external sharing, and contractors' usage and disposal once contracts are signed.
- **Trade secrets:** Trade secrets, confidential business dealings, offer a competitive advantage and require protection through legal and technical measures like NDAs, employment contracts, restricting access, and monitoring data flows.
- **Customer data:** Customer data is crucial for businesses, requiring careful handling to maintain trust and comply with privacy laws, including sensitive personal and account manager data.
- **Proprietary data,** often overlapping with intellectual property rights or trade secrets, is data generated by a company, including research or product development work.
- **Biometric data:** This is data collected from fingerprints or facial recognition scans.

- Data can be classified into **human-readable** and **non-human-readable** categories.
- **Human-readable data**, like text, images, and audio, is easily understood and encrypted.
- **Non-human-readable data**, like binary code and machine language, requires cryptographic algorithms and secure hardware modules.
- Some of the most common regulations are shown in the following table:

| Regulation                                                  | Description                                                                                        |
|-------------------------------------------------------------|----------------------------------------------------------------------------------------------------|
| General data Protection Regulation (GDPR)                   | EU laws guarding personal data rights and privacy in the digital realm.                            |
| Health Insurance Portability and Accountability Act (HIPAA) | U.S. regulations securing the privacy of health information.                                       |
| California Consumer Privacy Act (CCPA)                      | California legislation empowering consumer data rights and privacy                                 |
| Sarbanes-Oxley Act (SOX)                                    | U.S. law ensuring financial transparency and accountability for public companies                   |
| Gramm-Leach-Bliley Act (GLBA)                               | U.S. act imposing privacy and security rules on financial institutions                             |
| Data Protection Act (1998)                                  | This is statute law in the UK to protect and regulate personal data handling and safeguard privacy |
| Overview of key data protection and privacy regulations     |                                                                                                    |

# Data Classifications

Data classifications form the basis for data protection strategies, determining data handling, access, storage, and destruction based on sensitivity, risk, and potential damage in case of breach.

The following figure shows the governmental versus non governmental descriptions of data:

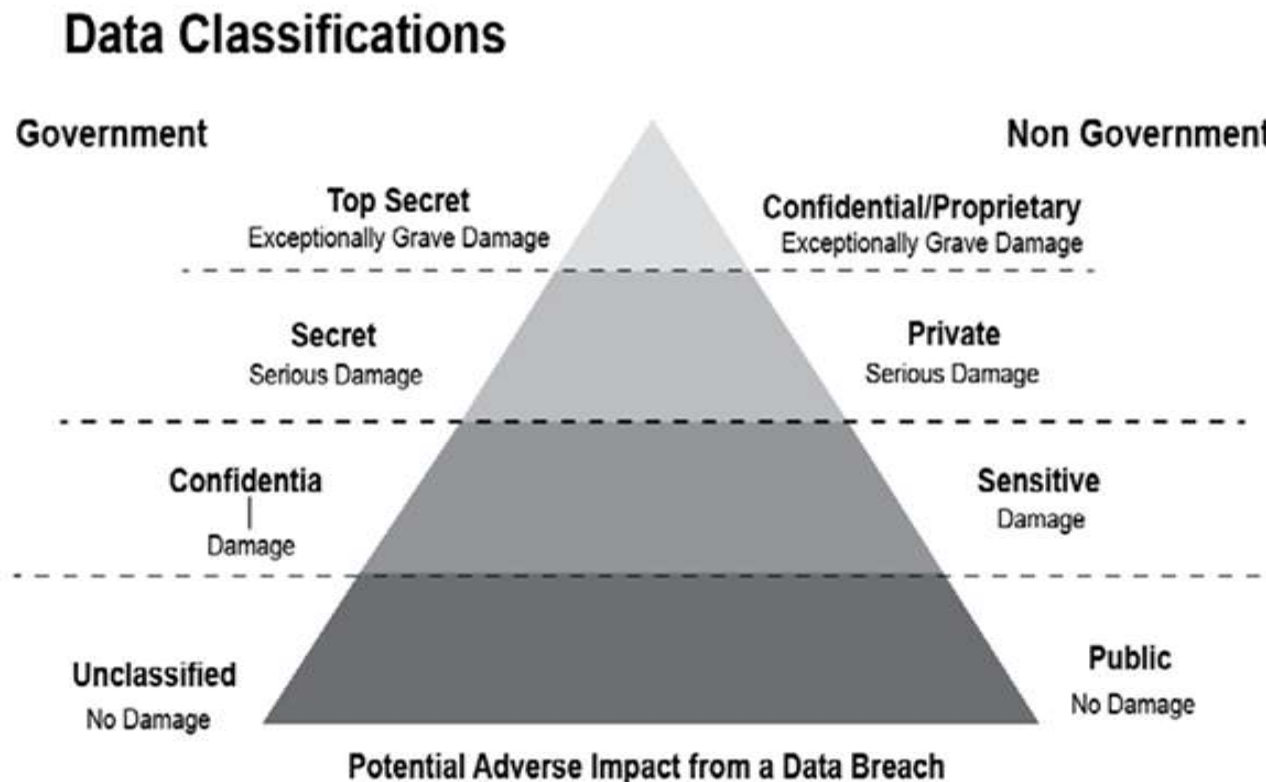


Figure 12.1: Governmental versus non-governmental data

# Data Classifications

- **Sensitive data**, also known as privileged information, is a valuable collection of personal, financial, or confidential details that require special protection to prevent harm or undesirable consequences.
- **Confidential data**, such as R&D and legal data, is protected by strict legal measures like attorney-client privilege, and access typically requires authorization or special permission.
- **Public data** refers to publicly available information, such as news, leaflets, or brochures distributed widely.
- **Restricted data**, also known as confidential information, requires limited access and strict security measures, including authorization and legal constraints, and may be restricted in use, distribution, or access.
- **Private data** is confidential information kept within a restricted circle of trust, not intended for public consumption, and potentially causing critical damage if exposed.
- **Critical data**, including backups and encryption keys, is vital for an organization's operation and can be classified and encrypted to prevent external access.

# General Data Considerations

In information security, understanding data classification, states, and legal/geographical implications is essential for effective data management and protection.

Data states define the context in which data resides and how it is accessed and utilized. There are three possible data states, described as follows:

- **Data at Rest:** Stored data (e.g., databases, hard drives). Needs encryption and access control.
- **Data in Transit:** Data being transmitted across networks. Protected by protocols like TLS, HTTPS.
- **Data in Use:** Data being actively processed (e.g., in RAM). Requires memory level protection.
- **Data Sovereignty:** Data must comply with the laws of the country where it's stored or processed.
- **Geolocation:** Helps verify access legitimacy by tracking physical origin of user requests.

# Methods to secure data

Protecting data is vital for any organization, and various methods are used to ensure its confidentiality, integrity, and availability. Key techniques include:

- **Geographic restrictions** restrict data access to users or devices in specific regions, ensuring compliance with jurisdictional regulations but potentially posing challenges for remote work and global collaborations.
- **Encryption** is a crucial aspect of data security, transforming plaintext into ciphertext that can only be deciphered with the correct private key.
- **Hashing** is a one-way function that converts data into a fixed-length string, ensuring data integrity. It is used to securely store passwords in databases. Common hash algorithms include MD5, SHA-1, 256, 512, and SHA-3. Changes in the original hash value indicate data tampering, while the same value indicates data integrity.
- **Data masking** is a method to safeguard sensitive or confidential data by replacing, hiding, or scrambling it with fake or anonymized data while maintaining its original format and structure.

The following are two examples of masking social security numbers (all but the final three digits have been replaced with X to hide the data):

Original data:

Employee 1: Ian Neil, SSN: 123-45-6789

Employee 2: Jane Scott, SSN: 987-65-4321

Masked data:

Employee 1: Ian Neil, SSN: XXX-XX-X789

Employee 2: Jane Scott, SSN: XXX-XX-X321



# Methods to secure data

- **Tokenization** is a data security method where sensitive information is replaced with a random token, securely stored in a vault, commonly used for card payment processing.
- **Obfuscation** is a technique that makes source code or data complex or obscure, preventing theft by making it harder for competitors or unauthorized users to understand. Obfuscation can involve various methods, including XOR and ROT13 for data masking.
  - **XOR** is a logical operation that compares two binary values, 0s and 1s, and outputs 0 if they are the same, and 1 if they are different.
  - **ROT13** is a 13-place logical operation, a variation of the Caesar cipher, where 26 letters are rotated 13 times, with the key being the same.

To send the message TIME FOR TEA, we would locate each letter of our desired message and replace it with the one directly beneath it in the preceding table (the letter 13 places over in the alphabet). The result for this example would thus be GVZR SBE GRN. This means we have moved the letter 13 places further on. When receiving the message GVZR SBE GRN, we would again apply ROT13, but instead of going forward 13 places to decipher, we would simply reverse the process by going back 13 places (or moving from the bottom to the top row in the preceding table) to decipher the message TIME FOR TEA.

|        |   |   |   |   |   |   |   |   |   |   |   |   |   |
|--------|---|---|---|---|---|---|---|---|---|---|---|---|---|
| Letter | A | B | C | D | E | F | G | H | I | J | K | L | M |
| ROT 13 | N | O | P | Q | R | S | T | U | V | W | X | Y | Z |
|        |   |   |   |   |   |   |   |   |   |   |   |   |   |
| Letter | N | O | P | Q | R | S | T | U | V | W | X | Y | Z |
| ROT 13 | A | B | C | D | E | F | G | H | I | J | K | L | M |

Table 12.2: ROT13 logical operation key

# Methods to secure data

- **Segmentation** is a strategic approach to network design that divides a system into isolated segments, thereby limiting lateral movement for cyber threats.
- **Permission restrictions** restrict data access and modification based on user roles and privileges, ensuring only authorized personnel can handle sensitive information.